信息安全测评与风险评估

7.2.1 移动互联架构认知



授课教师：杨迎

目录

CONTENTS

01 案例导入——“WiFi是免费的，但数据不是”

02 学习目标

03 移动互联系统架构 —— “端管云”三层模型

04 移动终端 —— 安全风险最大的“端”

案例导入——“WiFi是免费的，但数据不是”

引入问题

你的手机连接公司WiFi，流量会经过哪些“关卡”？

案例素材

某员工连接未加密公共WiFi登录移动OA，凭证被截获致内网数据泄露。调查发现：移动办公APP未启用传输加密，无线接入点未设身份认证。



问题讨论

- 为什么连接公共WiFi会存在安全隐患？
- 移动终端接入企业内网需要经过哪些安全“关卡”？
- 等保2.0为什么要单独设置“移动互联安全扩展要求”？

结论：移动互联安全关注“端（终端）、管（网络）、云（应用）”三个层面的安全保护。

学习目标

通过本课学习，你将能够：

理解

移动互联系统的三个核心组成部分

掌握

移动互联的安全风险及其成因

了解

等保2.0移动互联安全扩展要求的框架

能够

识别移动互联环境中的安全隐患

移动互联系统架构——“端管云”三层模型

移动互联系统 = 移动终端 + 无线网络 + 移动应用

层次	组成部分	典型设备/形态	安全关注点
端（终端层）	移动终端（手机、平板、专用终端）	智能手机、PAD、POS机等	设备丢失、数据泄露、恶意软件
管（网络层）	无线网络 + 接入网关	WiFi AP、无线接入网关	信号劫持、非法接入、中间人攻击
云（应用/服务层）	移动应用 + 云端服务平台（含服务器集群、数据库、中间件等后端资源）	云服务器（如阿里云ECS）、容器集群（如K8s）、云数据库（如MySQL云服务）、SaaS/PaaS平台（如钉钉、企业微信）	代码漏洞、权限滥用、数据泄露

移动终端 —— 安全风险最大的“端”



设备丢失/被盗

终端中存储的企业数据可能泄露。

常见场景：手机丢失，未启用远程擦除。



恶意软件感染

木马、间谍软件窃取数据。

常见场景：安装非官方渠道APP。



操作系统漏洞

系统未及时更新补丁。

常见场景：老旧安卓系统未修复已知漏洞。



未授权访问

屏幕锁定被绕过、root/越狱后权限失控。

常见场景：解锁密码过于简单。

无线网络 —— 最容易受到攻击的“管”



无线网络的开放性使其成为移动互联安全中最薄弱的环节。

01 中间人攻击

攻击者截取并篡改通信数据。典型攻击方式：伪造WiFi热点（Evil Twin）。

02 非法接入

未经授权的设备接入企业WiFi。典型攻击方式：破解WiFi密码或蹭网。

03 无线信号劫持

利用无线协议漏洞控制设备。典型攻击方式：Deauth攻击、重放攻击。

04 弱加密破解

破解WEP/WPA等脆弱加密协议。典型攻击方式：字典攻击、暴力破解。

移动应用 —— 承载业务的“云”

移动应用的安全漏洞可能直接导致企业数据泄露。



逆向工程

APK被反编译，代码逻辑暴露。

示例：未做混淆的APP被破解。

数据明文存储

敏感数据以明文形式保存在本地。

示例：登录口令存于SharedPreferences。

不安全的传输

数据在传输过程中未加密。

示例：HTTP明文传输，缺少证书校验。

权限滥用

申请与业务无关的敏感权限。

示例：读取通讯录、位置等无关权限。

– 移动办公场景（BYOD）的安全挑战

BYOD 面临的核心矛盾：

- **企业：**需要保护数据安全，希望设备受控
- **员工：**希望保护个人隐私，不想被过度监控



常见管控措施：

01 MDM 移动设备管理	统一管理设备，下发策略。 **利弊分析：**企业掌控力强，但员工抵触。
02 MAM 移动应用管理	仅管理企业应用，不管个人应用。 **利弊分析：**平衡企业安全与员工隐私。
03 容器化 工作与个人分离	在设备中划分“工作区”和“个人区”。 **利弊分析：**目前最优方案。

移动互联安全扩展要求的范围



素材3：等保2.0移动互联安全扩展要求

GB/T 22239-2019 移动互联安全扩展要求覆盖5个维度：

1	2	3	4	5
安全物理环境	**安全区域边界**	**安全计算环境**	**安全建设管理**	**安全运维管理**
无线接入点的物理位置（7.3.1/8.3.1）	边界防护、访问控制、入侵防范（7.3.2/8.3.2）	移动终端管控、移动应用管控（7.3.3/8.3.3）	移动应用软件采购与开发（7.3.4/8.3.4）	配置管理（合法设备配置库）（8.3.5）

第一级/第二级 vs 第三级/第四级的差异

维度	第二级要求	第三/四级增强要求
物理环境	无线接入点合理位置	同左
区域边界-边界防护	有线与无线网络通过网关连接	同左
区域边界-访问控制	开启接入认证，禁止WEP	**支持认证服务器或国密认证**
区域边界-入侵防范	—（第二级无此要求）	**检测非法设备、攻击行为、阻断功能**
计算环境-终端管控	选择安装运行功能	**强制安装MDM客户端、远程锁定/擦除**
计算环境-应用管控	选择安装运行功能	**指定证书签名、白名单机制**

教师演示——移动互联网络拓扑演示

网络连接路径

移动终端 → WiFi AP → **无线接入网关** → 企业内网 → 应用服务器

演示步骤

素材1：移动互联网络拓扑图.docx

- **移动终端：**展示典型设备类型
- **无线接入点：**强调“不能过度覆盖”
- **无线接入网关：**强调“边界防护”作用
- **企业内网：**强调“有线与无线边界”隔离

重点强调：等保测评中检查“有线与无线网络边界之间是否通过无线接入网关设备”



实践任务1——移动互联架构图绘制（15分钟）

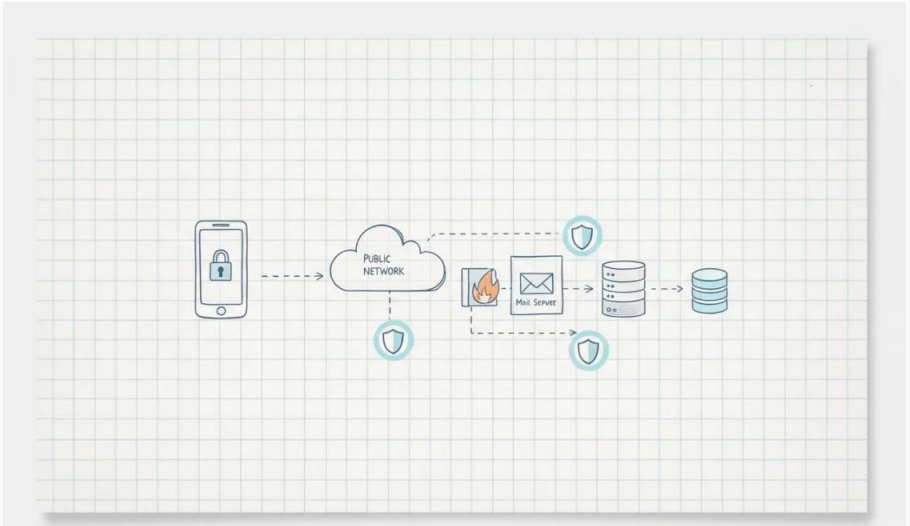
任务名称：绘制企业移动办公安全架构图

任务场景：某企业允许员工使用手机访问内部邮件系统，要求画出带安全控制点的架构图。

任务内容：

1. 标注各组件名称
2. 标注至少**3个**安全控制点（并说明对应标准）
3. 说明哪些环节是等保检查重点

时间安排：约15分钟



在此区域绘制架构图

实践任务2——安全隐患识别

素材2：安全隐患识别场景.docx

任务名称 **识别移动互联场景中的安全隐患**

任务场景

提供5个移动办公场景（见素材2），学生识别安全隐患并分析风险

任务内容

1. 阅读场景描述
2. 标注存在的安全问题
3. 分析可能导致的后果
4. 提出初步改进建议



时间安排：约15分钟

思政融入——移动安全无小事

公私分明

个人设备用于工作，企业数据与个人数据需要隔离。不将工作数据保存在个人设备中。

合规先行

移动互联系统同样需要等保测评。无论是公有云还是移动办公，都不是法外之地。

责任共担

移动安全不仅是IT部门的事，也是每个员工的事。不随意连接未知WiFi，不安装来路不明的APP。

一句话： 移动互联拓展了工作的边界，也拓展了安全的边界。

知识点回顾（5分钟）

移动互联架构认知

- **一、移动互联系统组成**
  - 端：移动终端（手机/平板/专用终端）
  - 管：无线网络（WiFi AP + 无线接入网关）
  - 云：移动应用（APP + 后台服务器）
- **二、三大安全风险**
  - 终端风险（丢失、恶意软件、系统漏洞）
  - 网络风险（中间人攻击、非法接入）
  - 应用风险（逆向工程、明文存储）
- **三、等保2.0移动互联安全扩展要求**
  - 5个维度：物理环境→区域边界→计算环境→建设管理→运维管理
  - 核心要求：接入认证、边界防护、终端管控
- **四、防护策略**
  - MDM/MAM（设备与应用管理）
  - 容器化（工作与个人数据分离）

课后作业

01

必做

提交《移动互联安全隐患分析表》

02

必做

完成活动7.2.1在线测试（选择题+判断题，共15题）

03

选做

调研一种移动终端管理（MDM）产品，总结其功能

04

预习

预习7.2.2“移动安全配置核查”相关内容

感谢观看

